

Clase 149 — Comunicaciones de comando y control (C2) del malware

Parte: **6 — Análisis de malware** · Fuente: *Practical Malware Analysis* (Sikorski & Honig) y MITRE ATT&CK  Duración estimada: **120 min** · Nivel: **Avanzado**

Objetivo

Entender y diseccionar el canal de **comando y control**: cómo el malware localiza su servidor, qué protocolos usa, cómo estructura el beacon y qué cifrado/ofuscación aplica. El alumno aprenderá a capturar, decodificar y describir el C2, extraer configuración e IOCs de red, y reconocer frameworks conocidos (Cobalt Strike, Metasploit) por sus patrones.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Identificar** el mecanismo de resolución del C2 (dominio fijo, DGA, dead drop).
2. **Analizar** el patrón de beacon: intervalo, jitter, URLs y user-agent.
3. **Decodificar** el tráfico cuando el cifrado es simple (XOR/base64) o hay clave.
4. **Reconocer** frameworks de C2 por sus firmas de red y perfiles.
5. **Extraer** la configuración de C2 desde el binario o la memoria.

Temas

#	Tema	Por qué importa
1	Modelo de beacon y callback	Base del control remoto
2	Protocolos: HTTP/S, DNS, TCP crudo	Definen la detección
3	DGA y dead drop resolvers	C2 resiliente y sigiloso
4	Cifrado y ofuscación del tráfico	Ocultar comandos y datos
5	Frameworks (Cobalt Strike, Sliver, Metasploit)	Patrones reconocibles
6	Extracción de configuración	IOCs y perfiles de red
7	Detección de red (JA3, Suricata)	Cazar C2 en producción

Definiciones y características

- **Beacon**: conexión periódica del implante al C2. Característica clave: **periodicidad + jitter**.
- **DGA (Domain Generation Algorithm)**: genera dominios pseudoaleatorios. Característica clave: **evita bloqueo por lista**.

- **Dead drop resolver:** obtiene el C2 desde un servicio legítimo (redes sociales, pastes). Característica clave: **camuflaje**.
- **Malleable C2:** perfiles que imitan tráfico legítimo (Cobalt Strike). Característica clave: **evasión de firmas**.
- **JA3/JA3S:** huella TLS del cliente/servidor. Característica clave: **detección aun con HTTPS**.

Herramientas y preparación

- **Wireshark** + **INetSim/FakeNet-NG** para capturar y responder.
- **CyberChef** para decodificar (base64, XOR, gunzip).
- **Suricata/Zeek** y firmas de red para detección.
- Extractores de config: **1768.py** (Cobalt Strike), **capa**, scripts de comunidad.

 **Nota ética y de seguridad:** el C2 se analiza con el servidor **simulado** (INetSim/FakeNet) dentro del lab aislado; nunca se da salida real a Internet ni se contacta un C2 vivo sin autorización. Montar servidores C2 solo se hace en entornos propios y con fines defensivos.

Laboratorio guiado

1. Restaura `base-clean`, arranca INetSim/FakeNet y captura con Wireshark en `labnet`.
2. Detona la muestra y observa la primera resolución DNS: ¿un dominio fijo o varios pseudoaleatorios (DGA)?
3. Sigue el flujo HTTP: anota método, URI, headers, **user-agent** y periodicidad de las peticiones (beacon interval + jitter).
4. Extrae el cuerpo de las peticiones/respuestas. Pásalo por **CyberChef** probando base64, XOR de un byte y gunzip para revelar comandos.
5. Si sospechas **Cobalt Strike**, usa `1768.py` sobre el beacon o la memoria para extraer el perfil (watermark, sleep, URIs, clave pública).
6. Localiza la **configuración de C2** en el binario/memoria (Ghidra/Volatility): dominios, puertos, clave, intervalo.
7. Calcula el **JA3** del handshake TLS (si aplica) y redacta una firma de detección (Suricata) para el patrón observado.
8. Documenta los IOCs de red y una regla de caza. Restaura `base-clean`.

Ejercicios

1. Diferencia beacon HTTP, DNS y TCP crudo por sus ventajas de evasión.
2. Explica cómo un DGA complica el bloqueo y cómo se puede predecir.
3. Decodifica un payload C2 simple con CyberChef y describe el comando.
4. Reconoce un perfil malleable y qué imita.
5. Escribe una firma Suricata para un user-agent o URI característico.
6. Extrae la config de C2 de una muestra y preséntala en tabla.

Reto verificable

Entrega un **informe de C2** de una muestra con: mecanismo de resolución, protocolo y patrón de beacon, config extraída (dominios/puertos/clave/intervalo), muestra de tráfico decodificado y una firma de detección de red. **Criterio de aceptación:** la firma propuesta dispara sobre el tráfico capturado en el lab y la config incluye al menos un dominio/IP y el intervalo de beacon verificados.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
No hay tráfico C2	Sin servicios simulados o detección de sandbox; usa INetSim y enmascara VM
No puedo descifrar el beacon	Cifrado fuerte; extrae la clave del binario/memoria
Beacon irregular	Jitter alto; promedia varios intervalos
Dominios cambian cada ejecución	DGA; identifica y reproduce el algoritmo
Firma con muchos falsos positivos	Basaste en algo genérico; usa URI+UA+patrón combinados

Preguntas frecuentes

 **¿Cómo detecto C2 cifrado con HTTPS?** Con metadatos: JA3/JA3S, SNI, tamaño y periodicidad de flujos, y reputación del destino, sin necesidad de descifrar.

 **¿Qué es un perfil malleable?** Una plantilla (Cobalt Strike) que define cómo luce el tráfico para imitar servicios legítimos y evadir firmas.

 **¿Puedo interactuar con el C2 real?** No sin autorización. Analiza con servidor simulado; contactar infraestructura del atacante puede alertarle o ser ilegal.

Referencias

- Sikorski & Honig, *Practical Malware Analysis*, cap. 14 (redes malware-céntricas).
- MITRE ATT&CK — Command and Control. <https://attack.mitre.org/tactics/TA0011/>
- CyberChef. <https://gchq.github.io/CyberChef/>
- Cobalt Strike config extractor (1768.py). <https://blog.didierstevens.com>

Siguiendo clase

Clase 150 - Ransomware: anatomía y análisis